

This article provides a detailed chronological account of the historical reception and criticism of security and privacy features in the WhatsApp messaging service.

2011

On May 20, 2011, an unidentified security researcher from the Netherlands under the pseudonym "WhatsappHack" published a method to hijack WhatsApp accounts using a flaw in the authentication process, to the Dutch websites Tweakers.net and GeenStijl. The method involved trying to log in to a person's account from another phone number and intercepting the verification text message that would be sent out. "WhatsappHack" provided methods to accomplish this on both Symbian and Android operating systems. One day after the publication of the articles, WhatsApp issued a patch to both the Android and Symbian clients.

In May 2011, another security hole was reported which left communication through WhatsApp susceptible to packet analysis. WhatsApp communications data was sent and received in plaintext, meaning messages could easily be read if packet traces were available.

2012

In May 2012 security researchers noticed that new updates of WhatsApp sent messages with encryption, but described the cryptographic method used as "broken." In August of the same year, the WhatsApp support staff stated that messages sent in the "latest version" of the WhatsApp software for iOS and Android (but not BlackBerry, Windows Phone, and Symbian) were encrypted, but did not specify the cryptographic method.

On January 6, 2012, an unknown hacker published a website that made it possible to change the status of any WhatsApp user, so long as the phone number associated with the user's account was known. On January 9, WhatsApp reported that it had resolved the problem. In reality, WhatsApp's solution had been to block the website's IP address, which had allowed a Windows tool to be made that could accomplish the same thing. This problem has since been

resolved by the institution of an IP address check on currently logged-in sessions.

On September 14, 2012, Heise Security demonstrated how to use WhatsAPI to hijack any WhatsApp account.

Shortly afterward, WhatsApp threatened to initiate legal action against the developers of WhatsAPI, an open source project, and WhatsAPI temporarily took down their source code.

This, however, did not address the underlying security failure and Heise Security claimed they had been able to successfully repeat the hacking of WhatsApp accounts. The WhatsAPI team has since resumed active development.

2013–2015

On March 31, 2013, the Saudi Arabia Communications and Information Technology Commission (CITC) issued a statement that mentioned possible measures against WhatsApp, among other applications, unless the service providers took serious steps to comply with monitoring and privacy regulations.

In February 2014, the Schleswig-Holstein Data Protection Authority advised against using WhatsApp, as the service lacked privacy protection such as end-to-end client-side encryption technology. In late 2014, WhatsApp began its implementation of end-to-end encryption, which it finished in April 2016.

A joint Canadian-Dutch government investigation was launched into several concerns over WhatsApp's compliance with security regulations. The primary concern of the investigators was that WhatsApp required users to upload their mobile phone's entire address book, including contact information for contacts who were not using WhatsApp, to be mirrored on WhatsApp's servers. While WhatsApp stored these phone numbers in hash, the data was not salted.

In late 2015, the Dutch government released a press statement claiming that WhatsApp had changed its hashing method, making it much harder to reverse, and thus subsequently

complied with all rules and regulations.

On December 1, 2014, Indrajeet Bhuyan and Saurav Kar demonstrated the WhatsApp Message Handler vulnerability, which allows anyone to remotely crash WhatsApp just by sending a specially crafted 2 kilobyte message. A user who receives the message must delete the whole conversation to avoid crashing WhatsApp upon opening the conversation.

In early 2015, after WhatsApp launched a web client that can be used from the browser, Bhuyan found that the client had two new security issues: the WhatsApp photo privacy bug and the WhatsApp web photo sync bug.

2016

On March 2, 2016, WhatsApp introduced a document-sharing feature, that allows users to share PDF files with contacts.

WhatsApp received criticism, however, about the default setting to automatically download attachments, which raised concerns about the downloading of malware and malicious files once the feature expands to include more than just PDFs.

In August 2016, WhatsApp announced that it will start sharing account information such as the phone number of the account owner and aggregated analytical data, with Facebook. WhatsApp claims that the address books, message content, and metadata of users would not be shared.

According to WhatsApp, this account information is shared to "track basic metrics about how often people use our services and better fight spam on WhatsApp. And by connecting your phone number with Facebook's systems, Facebook can offer better friend suggestions and show you more relevant ads if you have an account with them." It was further stated that "User data will not be shared with advertisers, and is only used internally on the Facebook services," and that users would be given the choice to opt-out of sharing this data with

Facebook for advertisement purposes.

In October 2016, the Article 29 Working Party stated that it has serious concerns regarding the way that the information relating to the updated Terms of Service and Privacy Policy was provided to users, and, consequently, about the validity of the users' consent.

From the latest client as of April 5, 2016, end-to-end encryption is supported for all of a user's communications, including file transfers and voice calls. It uses Curve25519 for key exchange, HKDF for generation of session keys (AES-256 in CBC mode for encryption and HMAC-SHA256 for integrity verification), and SHA512 for generating the two 30 digit fingerprints of both users' identity keys so that users can verify encryption. The encryption prevents even the company from being able to decrypt users' communications. This update was received well by security professionals and privacy enthusiasts, and the move was praised by Amnesty International. The US Federal Bureau of Investigation criticized the update as threatening the work of law enforcement.

In 2016, WhatsApp received a score of 6 out of 7 points on the Electronic Frontier Foundation's "Secure Messaging Scorecard". It has received points for having communications encrypted in transit, having communications encrypted with keys the provider doesn't have access to, allowing users to verify contacts' identities, having past messages secure if the encryption keys are stolen, having completed a recent independent security audit, and having the security designs properly documented. The missing seventh point is for the code not being open to independent review.

2017

On January 15, 2017, a research team from Ruhr University Bochum published a security analysis of group messaging protocols in WhatsApp and other messaging services, that found a privacy concern in that WhatsApp's servers effectively control the membership in groups. The report found that it would be therefore possible to add arbitrary phone numbers to a

group chat such that future communication becomes insecure.

In October 2017, the German software company Open-Xchange criticized WhatsApp, among others, for using proprietary software and stated plans to create an open-source alternative.

The Guardian Incident

On January 13, 2017, The Guardian reported that security researcher Tobias Boelter had found WhatsApp's policy of forcing re-encryption of initially undelivered messages, without informing the recipient, to constitute a loophole whereby WhatsApp could disclose the content of these messages.

WhatsApp and Open Whisper Systems officials disagreed with this assessment.

After complaints from 73 security researchers, The Guardian substantially revised and corrected their articles, and a follow up article from Boelter was removed. In June 2017, The Guardian readers' editor Paul Chadwick wrote that "The Guardian was wrong to report in January that the popular messaging service WhatsApp had a security flaw so serious that it was a huge threat to freedom of speech."

"In a detailed review I found that misinterpretations, mistakes and misunderstandings happened at several stages of the reporting and editing process. Cumulatively they produced an article that overstated its case."

Chadwick also noted that since the Guardian article, WhatsApp has been "better secured by the introduction of optional two-factor verification in February."

2019

In May 2019, it was revealed that there was a security vulnerability in WhatsApp, allowing a remote person to install a spyware just by making a call which does not even need to be answered. Later, in June 2019, another vulnerability was revealed, allowing a user to

transform an audio call into a video call, without the victim consent and without the victim noticing. A bug bounty of US\$5000 was offered for this bug.

In June 2019, WhatsApp announced that it would take legal action against users who send disproportionately high number of messages using their communication platform. The company reiterated that its platform was meant for private messaging or for businesses to interact with their customers through their business app. In a notification on their website the company stated "Beginning on December 7, 2019, WhatsApp will take legal action against those we determine are engaged in or assisting others in abuse that violates our terms of service, such as automated or bulk messaging".

In September 2019, WhatsApp was criticized for its implementation of a 'delete for everyone' feature. iOS users can elect to save media to their camera roll automatically. When a user deletes media for everyone, WhatsApp does not delete images saved in the iOS camera roll and so those users are able to keep the images. WhatsApp released a statement saying that "the feature is working properly," and that images stored in the camera roll cannot be deleted due to Apple's security layers.

In November 2019, WhatsApp released a new privacy feature that let users decide who adds them to the group.

In December 2019, WhatsApp confirmed a security flaw that would allow hackers to use a malicious GIF image file to gain access to the recipient's data. The flaw was first reported by a user named Awakened on GitHub with an explanation of how the exploit worked. When the recipient opened the gallery within WhatsApp, even if not sending the malicious image, the hack is triggered and the device and its contents become vulnerable. The flaw was patched and users were encouraged to update WhatsApp.

On December 17, 2019, WhatsApp fixed a security flaw that allowed cyber attackers to repeatedly crash the messaging application for all members of group chat, which could only be fixed by forcing the complete uninstall and reinstall of the app. The bug was discovered by

Check Point in August 2019 and reported to WhatsApp. It was fixed in version 2.19.246 onwards.

2020

In April 2020, WhatsApp sued the NSO Group for allegedly using the spyware it produces to hack at least 1,400 WhatsApp users. To which the company responded by claiming that it is not responsible for, nor can it control how its clients use its software. According to research by Citizen Lab countries which may have used the software to hack WhatsApp include, Saudi Arabia, Bahrain, Kazakhstan, Morocco, Mexico and the United Arab Emirates.

On 16 December 2020, as part of an anti-trust case against Google, a complaint was made that WhatsApp gave Google access to private messages. The complaint was heavily redacted due to being part of an ongoing case, and therefore it cannot be determined if the claim alleges tampering with the app's end-to-end encryption, or Google accessing user backups.

2021

In January 2021, WhatsApp announced an update to its Privacy Policy which states that WhatsApp would collect the metadata of users and share it with Facebook and its "family of companies" starting in February 2021. The new policy will not allow WhatsApp to see or send messages, which are still end-to-end encrypted, but it will allow Facebook to see data such as what phone and operating system a user has, the user's time zone, IP address, profile picture, status, phone number, app usage, and all of the contacts which are stored in WhatsApp. Previously, users could opt-out of such data sharing, but the new policy removed this option and required users to accept the policy in order to use the application.

This update generated considerable concern and debate, with privacy and data protection experts and legal scholars arguing that the new data-sharing policy violated the EU General Data Protection Regulation (GDPR). According to the experts, users could not be forced to

accept the new terms under the condition of being unable to use the application, as a kind of "punishment", since this would violate the principle of valid and freely given user consent. They also added that terms of use of this type would not be acceptable in the EU under GDPR regulations.

Due to GDPR regulations, WhatsApp had to exclude the European Union from this update to avoid penalties. Facebook and WhatsApp were widely criticized for this move, which led to a mass exodus to other messaging alternatives such as Telegram or Signal.

Facing pushback and lack of clarity about Facebook data sharing, WhatsApp postponed the implementation of the updated privacy policy from February 8, 2021, to May 15, 2021, but announced they have no plans to limit the functionality of the app for those who don't approve the new terms or to give them persistent reminders to do so.

ProPublica investigation

In September 2021, ProPublica published an extensive investigation into WhatsApp's use of outside contractors and artificial intelligence systems to examine user communication, and its collaboration with law enforcement. The investigation includes information from a complaint filed by a whistleblower with the U.S. Securities and Exchange Commission. Internal WhatsApp company documents revealed Facebook's considerable efforts to brand WhatsApp as "a paragon of privacy".

WhatsApp employs around 1000 contractors in their 20s and 30s, via Accenture, at offices in Austin, Texas, Dublin and Singapore. Their job is to review content reported by WhatsApp users, and pay starts at \$16.50/hour. When a user flags a message they've received, it and the previous four messages are decrypted and sent to this content review team. A reviewer has less than a minute to decide whether to do nothing, place the user on a watch list, or ban them. Due to pranks, ambiguous content, language nuances and translation errors, the process is prone to misunderstandings.

WhatsApp also uses artificial intelligence systems to scan unencrypted data collected from users (profile image and status; phone number, IMEI and OS; names and images of the user's WhatsApp groups; a list of the user's electronic devices; any Facebook or Instagram accounts) and compares it against suspicious patterns or terms and images previously deemed abusive. WhatsApp shares message metadata with law enforcement agencies such as the Department of Justice. If legally required, or at its own discretion (such as for investigating Facebook leaks), it can provide critical location or account information, or real-time data on the recipients messaged a target subject. WhatsApp message metadata has been used to help jail people such as whistleblower Natalie Edwards. In 2020, WhatsApp reported 400,000 instances of possible child-exploitation imagery to the National Center for Missing & Exploited Children.

2024

2024 FTC report

In September 2024, the Federal Trade Commission released a report summarizing 9 company responses (including from WhatsApp) to orders made by the agency pursuant to Section 6(b) of the Federal Trade Commission Act of 1914 to provide information about user and non-user data collection (including of children and teenagers) and data use by the companies that found that the companies' user and non-user data practices put individuals vulnerable to identity theft, stalking, unlawful discrimination, emotional distress and mental health issues, social stigma, and reputational harm.

== References ==